التاسك الشامل – الأمن السيبراني

تحليل نظام «المقصف أونلاين» (خيالي)

الاسم: تميم تركي الحارثي

الكلاس: 103

المادة: الأمن السيبراني

التاريخ: 1 نوفمبر 2026

كل التحليل على الورق لنظام خيالي. ما جربت شي على أي موقع أو جهاز أو حساب حقيقي.

الجزء أ: الأخلاقيات والصلاحيات

#	الموقف	التصنيف	ليش
1	أختبر قوة كلمة مرور حساب تدريبي أنشأته بنفسي، في معمل المدرسة وبإذن المدرب	مسموح	عندي **موافقة** المدرب، والحساب حقي، وكله داخل **النطاق** المحدد (المعمل + حساب تدريبي). ما فيه بيانات شخص ثاني، فما فيه مساس **بالخصوصية**.
2	زميلي يبغى يدخل حساب طالب ثاني في «المقصف أونلاين» عشان «يثبت إن النظام ضعيف»	ممنوع	ما فيه **موافقة** من صاحب الحساب ولا من المدرسة، والحساب خارج **النطاق**، وفيه اعتداء على **خصوصية** الطالب. النية الطيبة ما تخلي الفعل مسموح. الصح إنه يبلغ عن شكه بدل ما يجرب.
3	غيرت بالغلط `order=1043` إلى `order=1044` وطلعت لي فاتورة طالب ثاني	ممنوع أكمل	اللي صار بالغلط، بس اللي بعده هو المهم. أسوي بالضبط: **أتوقف** فورا وأقفل الصفحة، ما أجرب أرقام ثانية، ما أصور ولا أحفظ ولا أوري أحد الفاتورة (احترام **الخصوصية**)، وبعدها **أصعد** الموضوع وأسوي **إفصاح** مسؤول للجهة المعتمدة بالمدرسة: وش سويت وبأي وقت، بدون ما أنشر الثغرة لأحد ثاني.
4	أبغى أفحص شبكة المدرسة ببرنامج فحص عشان أساعد قسم التقنية، بدون ما يطلبون مني	يحتاج موافقة	الفحص ممكن يكون مفيد، بس لازم **موافقة** مكتوبة من قسم التقنية تحدد **النطاق** (أي أجهزة، أي وقت، وش الأدوات). بدونها يصير ممنوع، لأنه ممكن يبطئ الشبكة أو يكشف بيانات ما يحق لي أشوفها.

ليش إذن المدرب في المعمل ما يعطيني إذن أجرب على مواقع عامة أو خاصة؟ لأن الإذن يعطيه بس صاحب النظام، والمدرب يملك يعطيني إذن داخل المعمل وأجهزته فقط. المواقع الثانية لها أصحاب ثانيين ما وافقوا، فأي تجربة عليها تطلع من النطاق.

وما علاقة نظام مكافحة الجرائم المعلوماتية بالسعودية؟ النظام يجرم الدخول غير المشروع على أي موقع أو نظام أو حساب، والاطلاع على بيانات الناس أو التعدي على خصوصيتهم بدون إذن، وعقوبته سجن وغرامة. يعني الموقف 2 ممكن يكون جريمة حتى لو نيته «يثبت ضعف»، والموقف 3 لو كملت أتصفح فواتير الناس بعد ما عرفت يصير تعدي، أما الإبلاغ فهو التصرف الصحيح.

الجزء ب: الأصول ومصطلحات الخطر

1) الأصول

النوع	الأصل	الركن الأهم	ليش
معلومات	سجل حساسية الطلاب من الأكل في قاعدة البيانات	السلامة	لو أحد غير المعلومة (مثلا شال حساسية الفول السوداني) ممكن يتسلم الطالب أكل يضره صحيا. (والسرية مهمة بعد لأنها معلومة صحية خاصة.)
تقنية	الجهاز اللوحي اللي يشوف عليه الموظف الطلبات	التوفر	لو تعطل أو انقفل، الموظف ما يعرف الطلبات ويوقف التسليم وقت الفسحة.
خدمة	خدمة الطلب والدفع من المحفظة في الموقع	التوفر	الطلاب يعتمدون عليها بوقت قصير (الفسحة)، فلو طاحت ما أحد يقدر يطلب.
أشخاص	مسؤول النظام (صاحب حساب المدير)	السرية	هو اللي عنده كلمة مرور المدير، فلو انخدع وكشفها (مثلا برسالة تصيد) يقدر المهاجم يغير الأسعار ويشوف كل المبالغ.

2) سلسلة الخطر للحساب المشترك لموظفي المقصف

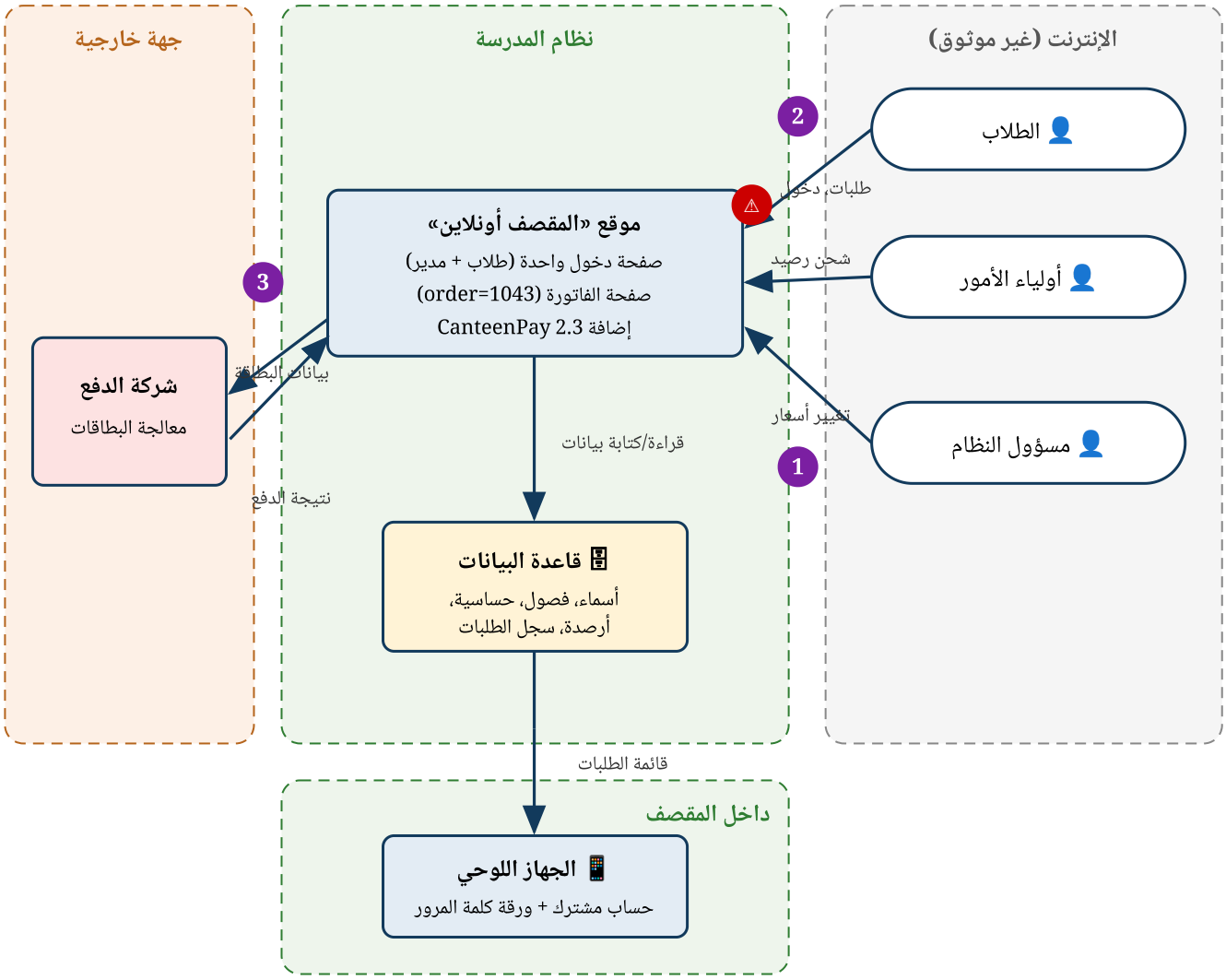
مصدر التهديد	حدث التهديد	الثغرة	الضابط المقترح	الأثر لو صار
أي شخص يمر جنب الجهاز ويشوف الورقة: طالب، زائر، أو موظف ترك الشغل.	يقرا كلمة المرور من الورقة ويدخل حساب المقصف، ويعلم طلبات إنها «تسلمت» أو يغيرها أو يطلع على بيانات الطلاب.	حساب واحد مشترك لكل الموظفين + كلمة المرور مكتوبة على ورقة مكشوفة.	حساب مستقل لكل موظف بكلمة مرور خاصة (أو رقم سري قصير مع قفل تلقائي للجهاز)، وإزالة الورقة، وتغيير كلمة المرور الحالية فورا.	طلبات تضيع أو تنصرف لغير أصحابها، خسارة فلوس، كشف بيانات الطلاب (حتى الحساسية)، وما نقدر نعرف مين سوى لأن الكل يدخل بنفس الحساب.

3) الفرق

الثغرة نقطة ضعف موجودة بالنظام (الورقة جنب الجهاز)، و**التهديد** احتمال إن أحد يستغلها (أحد يقرا الورقة ويدخل)، و**الحادثة** لما يصير الاستغلال فعلا (أحد دخل وغير طلب). الثغرة ممكن تبقى سنين بدون ما يصير شي.

الجزء ج: نمذجة التهديدات

1) مخطط النظام



المستطيلات المتقطعة = حدود الثقة. الأسهم = انتقال البيانات. ⚠ = الواجهة المكشوفة للإنترنت (الموقع وصفحة الدخول). الدوائر البنفسجية = أماكن التهديدات تحت.

2) ثلاث تهديدات من المخطط

#	التهديد	مكانه على المخطط
1	أحد من الإنترنت يخمن كلمة مرور المدير ويدخل حسابه، ويغير الأسعار أو يشوف كل المبالغ. ما فيه تحقق ثنائي يوقفه.	السهم من «مسؤول النظام» للموقع، عند صفحة الدخول المكشوفة للإنترنت (حد الثقة بين الإنترنت والمدرسة).
2	طالب يطلع على فواتير طلاب ثانيين بتغيير رقم الطلب بالرابط، فتنكشف أسماءهم وطلباتهم.	السهم من «الطلاب» لصفحة الفاتورة ? `order=` داخل الموقع.
3	ثغرة بإضافة الدفع أو مشكلة عند شركة الدفع تكشف بيانات بطاقات أولياء الأمور.	الأسهم بين الموقع وشركة الدفع، عند حد الثقة مع الجهة الخارجية.

الجزء د: تقييم الخطر ومعالجته

الخطر	الاحتمالية (1–5)	الأثر (1–5)	الدرجة	مدى تأكدك	الدليل من وصف النظام	المعالجة
اختراق حساب المدير وتغيير الأسعار أو سرقة الأرصدة	4	5	**20** عالي جدا	عالي	المدير يدخل من نفس صفحة الطلاب المكشوفة، بدون تحقق ثنائي، وما فيه سجل يوضح مين غير الأسعار.	**تقليل:** تفعيل التحقق الثنائي، وصفحة دخول خاصة بالمدير، وسجل للتغييرات. الأثر عالي جدا والاحتمالية عالية، والتكلفة قليلة (إعدادات)، فما يصلح نقبله.
كشف فواتير الطلاب عن طريق رقم الطلب بالرابط	4	3	**12** متوسط–عالي	عالي	الرابط ينتهي برقم الطلب `order=1043`، وفعلا تغيير رقم واحد بالغلط فتح فاتورة طالب ثاني.	**تقليل:** الموقع يتأكد إن الفاتورة تخص الشخص الداخل قبل ما يعرضها. الاحتمالية عالية لأنه سهل جدا، والإصلاح تعديل برمجي بسيط تكلفته أقل بكثير من مشكلة خصوصية.
تسرب بيانات بطاقات أولياء الأمور أو توقف الدفع بسبب شركة الدفع الخارجية	2	4	**8** متوسط	متوسط	الدفع بالبطاقات تعالجه جهة خارجية، والنظام يستخدم CanteenPay 2.3. ما نعرف كثير عن حمايتها، فتأكدي أقل.	**نقل:** المدرسة ما تخزن بيانات البطاقات وتخلي الشركة تتحملها، بعقد يلزمها بمعايير أمن الدفع وبالتعويض والإبلاغ لو صار تسريب. بناء نظام دفع خاص بالمدرسة تكلفته عالية جدا، فالنقل أنسب (مع تحديث الإضافة).

الدرجة = الاحتمالية × الأثر (من 25).

الجزء هـ: الدفاع بالعمق والضوابط

1) مبدأ الحد الأدنى من الصلاحيات

الدور	يقدر	ما يقدر
طالب	يدخل حسابه، يطلب، يشحن محفظته، ويشوف فواتيره ورصيده هو بس.	يشوف فواتير أو أرصدة غيره، يغير الأسعار، يعدل بيانات الحساسية بنفسه.
موظف مقصف	يدخل بحسابه الخاص، يشوف طلبات اليوم (اسم الطالب، الطلب، وتنبيه الحساسية)، ويعلم الطلب «تسلم».	يشوف الأرصدة أو بيانات البطاقات، يغير الأسعار، يضيف أو يحذف طلاب.
مسؤول النظام	يغير الأسعار، يضيف الطلاب، ويشوف التقارير والمبالغ، من صفحة مدير خاصة وبتحقق ثنائي.	يشوف رقم البطاقة كامل (يبقى عند شركة الدفع)، أو يستخدم حساب المدير للطلبات العادية، أو يحذف سجل التغييرات.

2) جدول الضوابط

	وقائي	كاشف	تصحيحي
أشخاص	توعية الموظفين والطلاب: ما أحد يطلب كلمة المرور، ولا تكتبها على ورق.	تشجيع الموظفين والطلاب يبلغون عن أي رسالة أو شي غريب يشوفونه.	تدريب سريع للي انخدع أو أخطأ، بدون لوم، عشان ما تتكرر.
إجراءات	سياسة: حساب لكل موظف، وموافقة مكتوبة قبل تغيير الأسعار.	مراجعة أسبوعية لسجل تغيير الأسعار والطلبات الغريبة.	خطة استجابة: مين نبلغ، وكيف نقفل الحساب ونغير كلمة المرور لو صار اختراق.
تقنية	تحقق ثنائي للمدير، وتحقق من صلاحية عرض الفاتورة، وتحديث CanteenPay إلى 2.4.	سجل يوضح مين غير الأسعار ومتى، وتنبيه لو صار دخول فاشل كثير.	نسخ احتياطية لقاعدة البيانات عشان نرجع الأسعار والأرصدة الصحيحة.

3) كيف تشتغل كطبقات

مثال على حساب المدير: **الطبقة الأولى** التوعية، فالمدير ما يعطي كلمة مروره لأحد. لو انخدع وكشفها، **الطبقة الثانية** التحقق الثنائي يمنع المهاجم يدخل بكلمة المرور بس. لو برضو قدر يدخل، **الطبقة الثالثة** سجل التغييرات والمراجعة الأسبوعية تكشف إن الأسعار تغيرت من حساب المدير بوقت غريب. وآخر شي **الطبقة الرابعة**: خطة الاستجابة والنسخ الاحتياطية ترجع الأسعار الصحيحة وتقفل الحساب. فما فيه ضابط واحد لو فشل يطيح النظام كله.

الجزء و: جهات التهديد وأنواع الضعف

1) تصنيف جهتي تهديد

	طالب يبغى أكل ببلاش	محتال من خارج المدرسة يبغى بيانات البطاقات
الدافع	مصلحة صغيرة (أكل مجاني) أو تحدي وفضول.	مالي: يبيع البيانات أو يستخدمها بالاحتيال.
القدرة	قليلة: يجرب أشياء بسيطة مثل تغيير رقم بالرابط أو استخدام كلمة مرور الورقة.	متوسطة إلى عالية: يعرف يسوي رسائل تصيد ويستغل ثغرات معروفة مثل ثغرة CanteenPay.
إمكانية الوصول	عالية: عنده حساب بالموقع، ويوقف قدام المقصف والجهاز اللوحي كل يوم.	من بعيد بس: عن طريق الإنترنت (صفحة الدخول، الإيميلات للموظفين، إضافة الدفع).
الهدف	رصيد المحفظة، والطلبات، وحساب المقصف المشترك.	بيانات بطاقات أولياء الأمور، وحساب المدير، وشركة الدفع.

2) أنواع الضعف

نقطة الضعف	النوع	السبب الجذري	النتيجة المحتملة
حساب واحد مشترك للموظفين وكلمة المرور على ورقة	إعداد غير آمن	اختاروا السهولة والسرعة وقت الزحمة، وما فيه سياسة لكلمات المرور.	أي أحد يدخل حساب المقصف، وما نقدر نعرف مين سوى أي شي.
المدير يدخل من نفس صفحة الطلاب بدون تحقق ثنائي	ضعف تصميم	النظام صمم بدون ما يفرقون بين الحساب العادي والحساب الحساس.	تخمين أو سرقة كلمة مرور المدير = تحكم كامل بالأسعار والمبالغ.
رابط الفاتورة ينتهي برقم الطلب	خلل تنفيذ	المبرمج نسي يكتب التحقق إن الفاتورة تخص المستخدم الداخل.	أي طالب يشوف فواتير غيره ← انتهاك خصوصية.
ما فيه سجل لتغيير الأسعار	ضابط مفقود	ما كان التسجيل من متطلبات النظام من البداية.	لو أحد تلاعب بالأسعار ما نكتشفه ولا نعرف مين.
إضافة CanteenPay الإصدار 2.3	ضابط مفقود (التحديثات)	الثغرة نفسها خلل تنفيذ عند الشركة، بس بقاء المدرسة على إصدار قديم سببه إنه ما فيه أحد مسؤول عن متابعة التحديثات.	تبقى المدرسة معرضة لثغرات معروفة ومنشورة.

3) الجهاز اللوحي البطيء

وش توضح الأدلة	الجهاز صار بطيء، وفيه برنامج الموظف ما يعرفه، والبطارية تخلص بسرعة.
وش نستنتج	ممكن يكون فيه برنامج ضار يشتغل بالخلفية، وممكن يكون له علاقة بأن الكل يعرف كلمة المرور. لازم نتعامل معه كاحتمال حادثة ونبلغ.
وش يبقى مجهول	وش هو البرنامج بالضبط؟ مين ثبته ومتى؟ هل هو ضار فعلا أو برنامج من قسم التقنية؟ هل سرق بيانات أو كلمات مرور؟

ليش المؤشرات دليل مو برهان؟ لأن كل مؤشر له أكثر من تفسير: البطء ممكن من تحديث، والبطارية ممكن قديمة، والبرنامج ممكن قسم التقنية ثبته. المؤشرات تخلينا نشك ونفحص، بس ما تثبت إنه فيه اختراق إلا بعد ما يفحص الجهاز المختص.

الجزء ز: النشرة الأمنية ودورة معالجة الثغرات

1) استخراج من النشرة

المنتج	إضافة الدفع CanteenPay
الإصدار	2.3 وما قبلها (والمدرسة على 2.3، يعني متأثرة)
الشرط	الثغرة تظهر بس إذا خيار «الدفع السريع» مفعل
الأثر	ممكن أحد يشوف آخر 4 أرقام من بطاقات مستخدمين ثانيين
المعالجة	التحديث إلى 2.4، أو إيقاف «الدفع السريع» مؤقتا

2) ليش الشدة «عالية» بس الخطر على المدرسة أقل؟

الشدة تقييم عام للثغرة نفسها عند كل اللي يستخدمون الإضافة، بس الخطر يعتمد على وضعنا إحنا (الاحتمالية × الأثر). المقصف أونلاين ما يستخدم «الدفع السريع»، والثغرة ما تشتغل إلا بهالشرط، فاحتمالية استغلالها عندنا قليلة جدا. وكمان الأثر محدود (آخر 4 أرقام بس، مو البطاقة كاملة). بس لازم نتأكد بنفسنا إن الخيار فعلا مقفل، ونحدث برضو لأن أحد ممكن يفعله بالغلط.

3) خطوات معالجة الثغرة

#	الخطوة	وش نسوي	المسؤول	الموعد
1	الاكتشاف	نقرا النشرة ونلاحظ إن إصدارنا 2.3 داخل الإصدارات المتأثرة.	مسؤول النظام	نفس يوم النشرة
2	التحقق	نتأكد من رقم الإصدار المثبت، وهل «الدفع السريع» مقفل فعلا بالإعدادات.	مسؤول النظام	خلال يوم
3	تحديد الأولوية	نقيم الخطر: الشرط غير مفعل ← خطر منخفض–متوسط، بس بيانات بطاقات فما نأجلها كثير.	مسؤول النظام + قسم التقنية	خلال يومين
4	الإصلاح	نحدث CanteenPay إلى 2.4 بوقت ما فيه طلبات (بعد الدوام)، مع نسخة احتياطية قبلها.	قسم التقنية	خلال أسبوع
5	التأكد	نتأكد إن الإصدار صار 2.4 والدفع يشتغل طبيعي، ونسجل إن الثغرة انقفلت.	مسؤول النظام	بعد التحديث مباشرة

الحماية المؤقتة لين يتم الإصلاح: نتأكد إن «الدفع السريع» مقفل ونمنع أي أحد يفعله، ونراقب عمليات الدفع لو فيه شي غريب.

الجزء ح: الهندسة الاجتماعية والإبلاغ

1) مؤشرات الإقناع

المؤشر	الكلمات اللي تثبته
الذريعة	«بسبب تحديث أمني، حساب المقصف بينقفل»: قصة مقنعة تبرر طلب كلمة المرور.
الاستعجال	«عاجل جدا»، «اليوم»، «الساعة 12 الظهر»، «خلال 30 دقيقة».
السلطة	«من: إدارة المدرسة»، «معك مدير المدرسة».
الندرة	«أول 3 موظفين يردون بس بتبقى حساباتهم شغالة».
مؤشرات الثقة	«السلام عليكم» (أسلوب مألوف)، اسم «إدارة المدرسة»، كلمة «تحديث أمني»، وكلمة «pay» بالنطاق عشان يبين إنه له علاقة بالمقصف.

2) التقييم

المرسل	الاسم «إدارة المدرسة» بس العنوان `admin@kantin-pay.example` مو من نطاق المدرسة، وكلمة «kantin» مكتوبة بطريقة غريبة عشان تشبه «canteen».
الرابط	`kantin-pay.example/login` نفس النطاق الغريب، مو موقع المقصف الرسمي، وصفحة دخول = هدفها تسرق كلمة المرور.
الطلب	يطلب اسم المستخدم وكلمة المرور بالرد. أي إدارة حقيقية ما تطلب كلمة مرور بالإيميل أبدا.
السياق	رسالة مفاجئة بدون أي إعلان قبلها، ومدير المدرسة عادة ما يتعامل مع حساب المقصف مباشرة، وفيها تهديد بقفل الحساب.

اللي يخليها مشبوهة: نطاق خارجي يقلد اسم المقصف + طلب كلمة المرور + ضغط بالوقت والسلطة والندرة كله مع بعض.

3) توقف، افحص، تحقق، بلغ

1. **توقف:** الموظف ما يرد، ما يضغط الرابط، ما يكتب كلمة المرور، حتى لو الوقت ضيق.
2. **افحص:** يشوف عنوان المرسل والرابط (بدون ما يفتحه)، ويلاحظ المؤشرات اللي فوق.
3. **تحقق:** يتصل بالإدارة أو مسؤول النظام برقم معروف عنده من قبل، مو برقم أو رابط من الرسالة، ويسأل هل فعلا فيه تحديث.
4. **بلغ:** يبلغ الجهة المعتمدة بالمدرسة (مسؤول النظام / قسم التقنية)، ويخلي الرسالة بدون ما يحذفها عشان يقدرون يفحصونها.

4) بلاغ الحادثة

> **إلى:** مسؤول النظام / قسم التقنية بالمدرسة
> **الموضوع:** رسالة تصيد مشبوهة وصلت لحساب المقصف
> **الوقت:** اليوم، الساعة (حسب وقت الوصول)
>
> **وش صار:** وصلت لإيميل المقصف رسالة باسم «إدارة المدرسة» من عنوان خارجي `kantin-pay.example`، تطلب اسم المستخدم وكلمة المرور خلال 30 دقيقة، وفيها رابط دخول.
>
> **وش سويت:** وقفت وما تفاعلت معها، تحققت من الإدارة بالرقم المعروف وأكدوا إنهم ما أرسلوها، وخليت الرسالة بالبريد عشان تفحصونها.
>
> **وش ما سويت:** ما ضغطت الرابط، ما كتبت ولا أرسلت كلمة المرور، ما رديت على المرسل، وما حولت الرسالة لأحد ثاني.

5) ليش ضغط الشغل وغموض الإجراءات يخلون الموظف يصدق؟

وقت الفسحة الموظف مشغول ومستعجل، فما عنده وقت يفكر ويفحص، والرسالة نفسها تستغل هذا بالاستعجال. ولو ما فيه إجراء واضح يقول «مين يغير كلمة المرور؟ وهل الإدارة ممكن تطلبها؟» بيحس إن الطلب ممكن يكون طبيعي ويخاف حسابه ينقفل. **الإجراء اللي يمنع هالشي:** قاعدة مكتوبة ومعلقة للموظفين: «ما أحد بالمدرسة يطلب كلمة المرور بالإيميل أبدا، وأي طلب مثل كذا تتحقق منه بالاتصال بمسؤول النظام على الرقم الفلاني وتبلغ عنه»، مع حسابات خاصة لكل موظف.

الجزء ط: رسالة توعية

احمِ حسابك في «المقصف أونلاين»

عزيزي الطالب، حسابك في المقصف فيه رصيد محفظتك ومعلوماتك، وحمايته سهلة. هذي ثلاث نصائح بسيطة:

1. كلمة مرورك لك أنت بس. اختر كلمة مرور طويلة يصعب تخمينها، ولا تقولها لأحد ولا تكتبها على ورقة، حتى لو أقرب صاحب لك.
2. إدارة المدرسة ما تطلب كلمة المرور أبدا، لا برسالة ولا بإيميل. لو جاتك رسالة مستعجلة تطلبها، لا تضغط الرابط وبلغ مسؤول النظام.
3. لو شفت بالغلط فاتورة أو معلومات طالب ثاني، اقفل الصفحة وبلغ، ولا تنشرها.

وإذا صار عندك أي شك، اسأل بدون تردد. بلاغك يحميك ويحمي زملاءك.

عدد كلمات الرسالة: حوالي 90 كلمة.